

Búsqueda de Materiales en Apoyo a la Seguridad Web

Brandon Rodrigo Méndez Méndez

brandonr.mendezm@gmail.com

Benemérita Universidad Autónoma de Puebla

Facultad de Ciencias de la Computación

Otoño 2025

Resumen: A continuación, se presenta una investigación detallada sobre los conceptos básicos de la ciberseguridad, así como las herramientas más conocidas y utilizadas en el ámbito del hacking ético, junto con sus aplicaciones, ventajas y desventajas. Esta investigación permite comprender la importancia de la ciberseguridad y del hacking ético como elementos esenciales para proteger la información y fortalecer la seguridad digital en la actualidad.

Palabras Clave: Ciberseguridad, malware, ransomware, firewalls, seguridad en la red, hacking ético, hacker, herramientas, proxys, DDoS, impacto, IP, phishing, ingeniería social, software, sistema, cifrado, hashes, vulnerabilidades.

1 Introducción

En este documento se detallan los conceptos básicos de la ciberseguridad, como qué es la seguridad en la red, la ciberseguridad y el hacking ético, además de los tipos de hackers. Se explica qué son las herramientas de hacking ético, sus tipos y las distintas aplicaciones que tiene cada una. Todo esto con el fin de conocer las ventajas que puede ofrecer el hacking y la seguridad en la vida diaria para así poder evitar algún ataque en el futuro.

1.1 ¿Qué es la seguridad en la red?

La seguridad en la red consiste en las acciones que se llevan a cabo para salvar una red de computadoras y los datos que contiene. Esto comprende un grupo de instrumentos tecnológicos, así como normas para usarlas. [1]

La seguridad en la red busca, ante todo, impedir que individuos sin autorización puedan acceder a los datos, alterarlos o interrumpir el funcionamiento de un sistema externo. [2]

La relevancia de la seguridad en la red incluye una gran cantidad de herramientas, tanto políticas como tecnológicas, así como diversos procesos para utilizarlas. Las medidas tecnológicas más frecuentes incluyen:

- **Firewalls:** Estas funcionan como unas barreras para filtrar el tráfico de entrada y salida según reglas establecidas anteriormente, con el fin de proteger la red interna de accesos no autorizados.
- **Sistemas de detección y prevención de intrusos (IDS/IPS):** Estos se encargan del monitoreo de la red para buscar actividades que puedan ser sospechosas y así prevenir ataques en tiempo real.
- **Redes privadas virtuales (VPN):** Nos permiten tener conexiones seguras y cifradas entre todos los usuarios remotos y en la red corporativa, para así proteger la información durante su transmisión.
- **Control de acceso:** Definimos a los usuarios que podrán tener acceder a determinados recursos y todos los permisos que tendrán, usando autenticación y autorización.
- **Cifrado de datos:** Se transformamos la información a un formato ilegible para que quienes no poseen la clave de descifrado, con esto protegemos a la comunicación y tenemos un almacenamiento de datos más seguro.
- **Antivirus y antimalware:** Nos ayudan a detectar y a eliminan todo software malicioso que pueda estar comprometiendo a los dispositivos que estén conectados a la red.

Además de todas las herramientas tecnológicas, la seguridad en la red también depende de factores como lo pueden ser políticas de uso y concienciación del personal, algunas pueden ser las siguientes:

- Se debe tener una actualización constante de los sistemas y software para detectar y corregir vulnerabilidades.
- Emplear contraseñas seguras y autenticación multifactor para prevenir robo de datos.
- Se debe brindar una capacitación adecuada a todo el personal sobre ataques comunes, como lo pueden ser el phishing o la famosa ingeniería social.
- Debemos tener un monitoreo continuo de la red para así poder detectar comportamientos inusuales en la red y prevenir ataques. [3]

Además de todas estas herramientas, la seguridad en la red también se debe incluir lo que es el cifrado de datos para tener una mayor protección de la información que esta en tránsito, el uso de antivirus y antimalware. También es esencial para prevenir cualquier infección en los dispositivos conectados a la red, y por último una correcta implementación de las políticas de actualización y parcheo en los software para evitar y prevenir vulnerabilidades. Es de suma importancia también la concienciación y una capacitación adecuada de todo el personal para que se puedan reconocer amenazas como el phishing o la ingeniería social, junto con una monitorización constante del tráfico en la red para detectar comportamientos inusuales. Todas estas medidas en conjunto ayudan a garantizar y tener una buena confidencialidad, integridad y disponibilidad de la información que pasa por nuestra red.

1.2 Que es la ciberseguridad

La ciberseguridad no es más que una de las ramas de la informática que se encarga y nos ayuda a proteger los sistemas, las redes y nuestros datos frente a ataques digitales. Actualmente con el crecimiento del internet y el uso de dispositivos conectados, el apartado de la ciberseguridad se ha vuelto primordial para todas las empresas como para los usuarios individuales. [4]

Algunas de las amenazas más comunes en la rama de la ciberseguridad incluyen el famoso phishing que es básicamente engañar al usuario para robar sus contraseñas, el malware que es el uso de software malicioso como por ejemplo algún virus o troyano, el ransomware que se encarga de secuestrar datos de mucho valor para pedir rescate, por último tenemos los ataques DDoS los cuales sobrecargan de peticiones a los servidores para dejarlos fuera de servicio. También no hay que olvidarnos de la famosa ingeniería social, que básicamente consiste en manipular a las personas para así obtener acceso a su información confidencial. [5]

Una vez conociendo todas estas amenazas y medidas básicas, la ciberseguridad también nos incluye y hace referencia a la protección de dispositivos móviles, los servidores en la nube y al Internet de las cosas (IoT), los cuales se han vuelto cada vez más comunes en empresas y hogares. También se debe contemplar la gestión de incidentes y planes de recuperación ante alguna amenaza, que nos permita responder y actuar rápidamente ante ataques maliciosos o algún fallo de nuestra seguridad, para minimizar el impacto del ataque.

Para esto se utilizan técnicas avanzadas como lo es el análisis de tráfico de la red, la inteligencia ante amenazas y la detección de los comportamientos o patrones anormales para poder anticipar y así poder prevenir cualquier ataque antes de que causen daños significativos. Al mismo tiempo, la

ciberseguridad esta regulada por aspectos legales y normativos, para garantizar el cumplimiento de las leyes de protección de datos y privacidad, como GDPR o Leyes de Protección de Datos locales.

Todo esto en conjunto, busca ayudar para proteger la información, garantizar la continuidad de los servicios y reducir riesgos, combinando las tecnologías, procesos y concienciación de los usuarios o del personal.

La ciberseguridad no solamente esta basa en las tecnologías, sino que también en la educación, ya que muchas veces, los errores de los propios humanos son la puerta más grande de entrada para la gran mayoría de los ataques. [6]

1.3 Ramas de la Ciberseguridad

La ciberseguridad esta dividida en varias ramas, cada una esta especializada en proteger diferentes partes del entorno digital. Estas ramas permiten abordar la seguridad desde distintos ángulos y niveles, algunas de las principals ramas, son las siguientes:

Principales ramas:

- **Seguridad de redes:** Esta enfoca en la protección de la infraestructura de la red, para evitar los accesos que no estén autorizados y ataques externos.
- **Seguridad de aplicaciones:** Se encarga de analizar y reforzar la seguridad de los programas y en las aplicaciones para evitar que estan puedan ser vulnerables.
- **Seguridad de la información:** Garantiza que todos los datos sean confidenciales, que sean íntegros y que estén disponibles cuando se necesiten o sean solicitados.
- **Informática forense:** Nos ayuda a investigar delitos digitales, recuperar evidencia importante y reconstruye y recrea eventos para un análisis legal.
- **Criptografía:** Esta utiliza técnicas de cifrado con el fin de proteger la información durante su transmisión o cuando está almacenada.
- **Ingeniería social:** Se encarga de estudiar el cómo los atacantes manipulan a las personas para obtener acceso ha informacion personal o de algún sistema a su cargo.

- **Ciberinteligencia:** Su función mas importante es analizar amenazas, los comportamientos maliciosos y todos los patrones de ataque para anticiparse ha ellos y poder prevenirlos.
- **Auditoría de seguridad:** Ayuda a evaluar la postura de la seguridad que tenga alguna una organización y asi poder propone mejoras en sus sistemas.

Todas estas ramas deben trabajar en conjunto para asi poder crear un entorno digital mucho más seguro y resiliente para los usuarios. [7]

1.4 Principales Ataques de Ciberseguridad del 2020 en adelante

Durante el alo 2020 en adelante se tuvo registro de varios ataques cibernéticos de gran impacto los cuales afectaron a empresas, gobiernos y organizaciones. [8]

Ataques destacados:

- **Facebook (2021):** Después de un caso de Abuso de Funcionalidad en 2019 se filtraron los datos personales de más de 500 millones de usuarios, incluyendo números telefónicos y correos electrónicos.
- **Amazon AWS (2021):** Fue victima de interrupciones en la gran mayoría de sus servicios de nube, lo que afecto a miles de empresas que dependen de esta infraestructura.
- **Consejería Jurídica del Poder Ejecutivo Federal (CJEF) 2024:** Fue una de las víctimas un ransomware por parte del grupo RansomHub, ataque que tuvo lugar el 15 de noviembre y culminó con el secuestro de más de 300GB de información, entre contratos, presupuestos e información de sus funcionarios.
- **Grupo Bimbo (2023):** El grupo detrás del golpe fue ransomware Medusa, quienes identicaron una función legítima para despuúes utilizar un data scraping para asi tener en su poder bases de datos, datos financieros, facturas, correos electronicos e información de empleados y clientes; exigían 6,5 millones de dólares como rescate para no revelar la información.
- **Volkswagen (2023):** Fueron víctimas de un ataque cibernético el cual resultó en el robo de aproximadamente 19,000 documentos del servidor de la compañía. Este ataque tuvo lugar en China y este esta vinculado con espionaje cibernético internacional.

- **Microsoft 2024:** Sufrieron un ataque de Password Spraying esto derivó en una violación de datos de su plataforma Azure, este ataque comprometió cientos de cuentas de ejecutivos de alto nivel, incluidas tomas de control de cuentas en la nube y tentativas de phishing. [9]

Todos estos ataques cibernéticos nos demuestran que los ciberataques no solo pueden afectar a empresas tecnológicas, sino también a servicios esenciales como lo pueden ser los de salud, energía y finanzas.

1.5 ¿Qué es un hacker?

Un hacker no es nada más que una persona con unos conocimientos muy avanzados en la informática que utiliza todos los conocimientos y habilidades para explorar, modificar o vulnerar algún o algunos sistemas digitales. Aunque estos muchas veces están asociados con delincuentes, pero hay que aclarar que no todos los hackers tienen malas intenciones. [10]

Originalmente, este término se usaba comúnmente para describir a personas creativas que eran capaces de resolver problemas técnicos. Con el tiempo, algunas de estas personas empezaron a usar sus conocimientos para vulnerar sistemas, lo que dio lugar a una mala y negativa imagen de los hackers. Sin embargo, hoy en día también existen hackers éticos estos suelen trabajar para mejorar la seguridad de los sistemas de empresas y organizaciones.

Lo que suele caracterizar a los hackers es su inmensa curiosidad, sus grandes capacidades de análisis y su gran dominio de lenguajes de programación, redes y sistemas operativos. [11]

1.6 Tipos de Hackers

Existen distintos tipos de hackers estos se pueden clasificar según sus intenciones y métodos. Los más conocidos son los siguientes: [12]

- **White Hat:** Son los hackers éticos estos trabajan para las empresas y su función es detectar vulnerabilidades en sus sistemas.
- **Black Hat:** Estos hackers son maliciosos, buscan robar información valiosa, dañar sistemas o buscan lucrar ilegalmente con el robo de datos.
- **Grey Hat:** Suelen actuar sin permiso o consentimiento previo, pero no causan daño o buscan lucrar. A veces estos simplemente revelan fallos en los sistemas públicamente.

- **Red Hat:** Atacan a los Black Hats como una forma de justicia digital.
- **Blue Hat:** Son expertos externos que prueban sistemas antes de su lanzamiento para corregir alguna vulnerabilidad.
- **Green Hat:** Simplemente son aprendices que están empezando en el mundo del hacking.
- **Script Kiddies:** Ellos usan herramientas sin entender cómo funcionan para dañar sistemas o robar información.
- **Hacktivistas:** Estos suelen tener motivaciones políticas o sociales para su actuar.
- **Ciberterroristas:** Buscan causar miedo o caos revelando información relevante de algún tema de interés social.
- **Espías corporativos:** Roban secretos industriales de algún sistema con el fin de poder beneficiar a alguna empresa o gobiernos.

1.7 ¿Qué es el hacking ético?

El hacking ético es la práctica legal en donde se simula algún ataque cibernético esto con el fin de identificar fallos de seguridad antes de que los delincuentes cibernéticos puedan aprovecharse de estos.

Los hackers éticos suelen trabajar con permiso de las empresas para ejecutar ataques siguiendo un proceso previamente estructurado.

Fases del hacking ético:

1. **Reconocimiento:** Aquí se recopila toda la información sobre el sistema que se va a vulnerar.
2. **Escaneo:** Se verifican los puertos y servicios que pueden estar comprometidos para identificar vulnerabilidades.
3. **Explotación:** Proceden a realizar pruebas controladas al sistema para verificar y identificar todos los fallos existentes.
4. **Mantenimiento del acceso:** Se evalúa la capacidad del sistema para detener y resistir algún ataque a largo plazo.
5. **Borrado de huellas:** Simulación de cómo un atacante eliminaría evidencia después de realizar su ataque.

6. **Informe:** Se realiza una documentación detallada de todos los hallazgos encontrados y de las recomendaciones para solucionar fallos.

Tipos de pruebas:

- **Caja blanca:** En esta el hacker tiene acceso total al sistema para poder realizar algún ataque.
- **Caja negra:** No se tiene información previa del sistema para realizar un ataque.
- **Caja gris:** Se tiene acceso parcial al sistema, como si se fuera un usuario común.

Este tipo de hacking y la estructura para realizar ataques de manera controlada es fundamental para prevención de ataques reales y así poder fortalecer la seguridad digital. [13]

1.8 Herramientas de Hacking Ético

Las herramientas de hacking ético son todos esos programas y scripts de software que utilizan los profesionales en el ámbito de la ciberseguridad para simular ciberataques. [14] Su objetivo principal es detectar y corregir fallos de seguridad en los sistemas informáticos, de redes y aplicaciones web antes de que un atacante pueda explotarlos. A diferencia de los hackers maliciosos, los hackers éticos suelen operar con el permiso explícito de los propietarios de los sistemas. [15]

Es como si una empresa contratara a un "ladrón" para que este intentará entrar a su domicilio, no para robar, sino con el fin de mostrarle dónde están las cerraduras débiles, las ventanas que no tienen seguro o los puntos ciegos de las cámaras. [16]

Usos y Aplicaciones Clave

Todas las herramientas de hacking ético son fundamentales en diversas áreas de la ciberseguridad. Su correcta implementación ayuda a tener una defensa robusta y segura de los sistemas.

Usos Principales

- **Pruebas de Penetración o Pentesting:** Este es de los usos más comunes. Consiste en realizar un ataque controlado y autorizado contra un sistema con el fin de poder evaluar su seguridad. Los hackers éticos utilizan estas herramientas para intentar penetrar las defensas y demostrar cómo un atacante real podría hacerlo.
- **Análisis de Vulnerabilidades:** Utilizamos herramientas automatizadas, como lo son escáneres, con el fin de identificar debilidades que ya tengan los sistemas, redes o aplicaciones. Esto nos proporciona una visión general de los posibles puntos de entrada que tendría un atacante a nuestro sistema.
- **Auditoría de Seguridad de Redes:** Son herramientas como los analizadores de protocolos y escáneres de puertos que se utilizan para mapear una red y así identificar los dispositivos conectados y analizar el tráfico en busca de datos no cifrados o de alguna actividad sospechosa.
- **Evaluación de Seguridad de Aplicaciones Web:** Se utilizan proxies de intercepción para analizar el cómo funciona una aplicación web y manipular las solicitudes que se envían al servidor con el fin de descubrir fallos como las inyecciones de código SQL. [17]

Implementación en la Práctica

La implementación de estas herramientas como toda práctica sigue un proceso ya definido y que suele estar dividido en las siguientes fases:

1. **Reconocimiento:** Esta es la fase inicial de recopilación de la información. Se utilizan herramientas para poder descubrir direcciones IP, nombres de algún dominio, información de contacto de empleados y las tecnologías que utiliza el objetivo.
2. **Escaneo y Enumeración:** Utilizamos escáneres de puertos y de vulnerabilidades con el fin de identificar sistemas activos, puertos que estén abiertos y servicios que se encuentren en ejecución. El objetivo principal es crear un mapa detallado de la superficie de ataque.
3. **Obtención de Acceso (Explotación):** En esta fase, los hackers éticos intentan explotar las vulnerabilidades existentes en los sistemas utilizando herramientas como pueden ser los Metasploit para poder obtener acceso no autorizado al sistema.
4. **Mantenimiento del Acceso:** Ya una vez dentro, se suelen usar herramientas para mantener el acceso al sistema y posteriormente

escalar privilegios, demostrando el impacto potencialmente dañino que puede tener una brecha de seguridad.

5. **Análisis y Reporte:** Para finalizar se debe documentar todos los hallazgos obtenidos, para generar un informe detallado donde se describan todas las vulnerabilidades, el cómo fueron explotadas y, lo más importante, el cómo se pueden solucionar. [18]

Algunas de las herramientas de hacking ético más conocidas son:

1. Nmap (Network Mapper)

Nmap es una herramienta de código abierto que sirve para la exploración de redes y la auditoría de la seguridad. Se utiliza por los administradores de sistemas y por los profesionales de la ciberseguridad para poder descubrir dispositivos en una red, identificar todos los servicios que nos ofrecen, todos los puertos que tienen abiertos, el sistema operativo que están ejecutando y qué tipos de filtros de paquetes o firewalls se utilizan. Su gran versatilidad la hace una de las primeras herramientas más usadas en las fases de reconocimiento de una prueba de penetración.

- **Funcionalidades clave:**

- **Detección de hosts:** Puede identificar los dispositivos que se encuentren conectados a una red.
- **Escaneo de puertos:** Determinan todos los puertos que están abiertos, que estén cerrados o filtrados en un host.
- **Detección de versiones:** Averiguan la versión de todos los servicios que se ejecutan en los puertos que están abiertos.
- **Detección de sistema operativo:** Identifica el sistema operativo del objetivo basándose en su comportamiento en la red.
- **NSE:** Dejas a los usuarios escribir, compartir y utilizar scripts para automatizar una amplia variedad de tareas de red y detectar vulnerabilidades. [19]

2. Metasploit Framework

Metasploit es una de las herramientas de pruebas de penetración más potentes y utilizadas en el mundo. Es un proyecto de código abierto que proporciona información sobre vulnerabilidades de

seguridad existentes en un sistema y ayuda en el desarrollo de exploits y de pruebas de penetración. Cuenta con una vasta base de datos de exploits, payloads y de herramientas auxiliares que permiten a los hackers éticos simular cualquier tipo de ataque del mundo real contra las redes, sistemas operativos, aplicaciones y bases de datos con el fin de identificar puntos débiles de éstas.

Usos y aplicaciones

The Metasploit Framework es la principal herramienta para las fases de explotación y post-explotación en cualquier prueba de pentesting, a continuación listamos algunos de los principales usos de esta herramienta.

- **Validación de Vulnerabilidades:** Este es su uso más común, ya que después de realizar un escáner para reportar las vulnerabilidades más críticas, usamos Metasploit para demostrar que esas vulnerabilidades son realmente explotables.
- **Ejecución de Exploits:** Tiene una de las bases de datos de *exploits* públicos más grande y organizadas del mundo, lo que simplifica el trabajo, simplemente se busca la vulnerabilidad en cuestión y si existe un modelo adecuado, se configura el exploit y se utiliza.
- **Generación de Payloads:** Te permite crear payloads como un shell inverso meterpreter, que es lo que te da el control del sistema víctima una vez que el exploit funciona.
- **Post-Explotación:** Una vez que se tiene acceso, Metasploit ofrece módulos para escalar privilegios, moverse a otras máquinas, obtener contraseñas o demás.
- **Desarrollo de Exploits:** Los investigadores la usan para escribir y probar nuevos exploits para vulnerabilidades recién descubiertas. [6]

Ventajas

- **Es el Estándar de la Industria:** Todo profesional de ciberseguridad ofensiva debe conocer Metasploit.
- **Modular y Flexible:** Su arquitectura te permite combinar exploits para poder entrar al sistema y a su vez, payloads que nos sirven ya una vez dentro y encoders para buscar código de una forma sencilla.

- **Código Abierto:** La versión Framework es gratuita y también es extremadamente potente.
- **Integración:** Se integra perfectamente con otras herramientas. Puedes importar los reportes de Nessus o Nmap a Metasploit para lanzar ataques automáticamente contra los objetivos encontrados.

Desventajas

- **Detectado por AV/EDR:** Al ser tan popular, *todos* los antivirus y sistemas de detección (EDR) detectan los *payloads* y módulos estándar de Metasploit. Requiere técnicas de evasión para usarse en entornos modernos.
- **Versión Gratuita vs. Pro:** La versión gratuita es la framework con ella se trabaja por medio de la línea de comandos. La versión comercial (Metasploit Pro) tiene una interfaz gráfica, automatización y reportes, pero es muy costosa.
- **No es fácil de usar:** Aunque ayuda a simplificar la explotación, requiere un entendimiento y conocimientos técnicos previos de las áreas de redes, protocolos y sistemas operativos para usarla eficazmente. [7]

2.1 ¿Como defenderse de Metasploit?

Una forma de mitigar el uso de Metasploit es la defensa contra exploits que suelen ser muy utilizados. Por ejemplo una de las mejores estrategias es un sólido programa para la gestion de parches. Si mantenemos el sistema con todas sus actualizaciones de seguridad de una forma constante, la gran mayoría de los exploits que son publicos se vuelven inservibles.

Funcionalidades clave:

- **Framework de explotación:** Ofrece una gran colección de exploits probados y listos para usar en cualquier momento.
- **Módulos auxiliares:** Se incluyen escáneres, fuzzers y herramientas de denegación de servicio para realizar cualquier tarea de reconocimiento y análisis.

- **Payloads:** Nos permite generar código malicioso que se ejecutará en los sistemas operativos objetivos después de una explotación exitosa, otorgando control remoto del sistema.
- **Módulos de post-explotación:** Facilita la recopilación de información y la escalada de privilegios una vez que se ha comprometido un sistema. [20]

3. Burp Suite

Burp Suite es la herramienta por excelencia para la seguridad de aplicaciones web. Funciona como un proxy de interceptación que se sitúa entre el navegador del usuario y la aplicación web objetivo, permitiendo al auditor inspeccionar, modificar y reenviar el tráfico HTTP/S. Esto es crucial para descubrir y explotar vulnerabilidades como Cross-Site Scripting (XSS), Inyección SQL, y problemas de gestión de sesiones.

- **Funcionalidades clave:**
 - **Proxy de interceptación:** Permite ver y manipular todas las peticiones y respuestas entre el navegador y el servidor.
 - **Scanner:** Automatiza la búsqueda de vulnerabilidades comunes en aplicaciones web.
 - **Intruder:** Realiza ataques personalizados y automatizados para probar parámetros, como ataques de fuerza bruta o fuzzing.
 - **Repeater:** Permite modificar y reenviar peticiones individuales de forma manual para analizar la respuesta del servidor.
 - **Sequencer:** Analiza la aleatoriedad de los tokens de sesión y otros datos que deberían ser impredecibles. [21]

4. Wireshark

Wireshark es un analizador de protocolos de red, considerado el estándar de facto en la industria. Permite capturar y examinar en detalle el tráfico que pasa por una red. Para un hacker ético, es una herramienta indispensable para solucionar problemas de red, analizar el comportamiento de aplicaciones, y lo más importante, inspeccionar protocolos de seguridad y detectar actividades sospechosas o tráfico no cifrado que pueda contener información sensible.

Funcionalidades clave:

- **Captura de paquetes en vivo:** Captura tráfico de una gran variedad de interfaces de red (Ethernet, Wi-Fi, Bluetooth).
- **Análisis profundo de protocolos:** Decodifica cientos de protocolos, mostrando cada campo y su significado.
- **Filtros de visualización:** Permite filtrar el tráfico por protocolo, dirección IP, puerto y otros criterios para aislar la información relevante.
- **Análisis de VoIP:** Puede analizar y reconstruir llamadas de voz sobre IP. [22]

5. Nessus

Nessus es uno de los escáneres de vulnerabilidades más populares y completos del mercado. Desarrollado por Tenable, ayuda a identificar rápidamente fallos de seguridad en sistemas, redes y aplicaciones. Nessus utiliza una extensa base de datos de vulnerabilidades conocidas (CVEs) para escanear los objetivos en busca de software desactualizado, parches faltantes, configuraciones incorrectas y otras debilidades que podrían ser explotadas por un atacante.

Funcionalidades clave:

- **Escaneo de alta velocidad:** Realiza evaluaciones de miles de dispositivos de forma rápida y precisa.
- **Cobertura completa:** Identifica vulnerabilidades en una amplia gama de sistemas operativos, dispositivos de red, hipervisores, bases de datos y aplicaciones web.
- **Informes personalizables:** Genera informes detallados sobre las vulnerabilidades encontradas, incluyendo su nivel de riesgo y recomendaciones para solucionarlas.
- **Escaneo con y sin credenciales:** podemos escanear sistemas sin autenticarnos con ellos para verificar qué 'puede ver' un atacante externo o escanearnos a nosotros mismos para realizar un análisis más profundo del sistema.
- **Detección de Malware y Botnets.** Esta es una técnica que puede darnos una señal de sospecha para verificar si hay sistemas infectados que también pueden estar está siendo utilizado en una red de bots.
- **Escaneo de cumplimiento:** Verifica si los sistemas cumplen con políticas de seguridad específicas (como CIS, DISA STIGs). [23]

Usos e Implementación en el Mundo Real

- **Auditorias de Seguridad:** Las empresas suelen programar algunos escaneos cada determinado tiempo lo que ayuda a mantener una buena seguridad.
- **Pruebas de Pentesting:** Antes de realizar un ataque, los hackers eticos utilizan Nessus, para encontrar puntos de entrada de fácil acceso.
- **Análisis de Cumplimiento:** Las empresas tiene que cumplir con las regulaciones PCI DSS y HIPAA establecidas, Nessus genera informes para demostrar que el sistema está configurado correctamente.
- **Antes de lanzar un Servidor:** Antes de que un nuevo servidor o aplicación se pueda conectar a la red de trabajo se debe escanear con Nessus para evitar nuevas vulnerabilidades en el sistema. [29]

6. John the Ripper

John the Ripper es una herramienta clásica y muy potente para el cracking de contraseñas. Su propósito principal es detectar contraseñas débiles. Funciona tomando hashes de contraseñas (el formato cifrado en que se almacenan las contraseñas) y tratando de adivinar la contraseña original mediante diversas técnicas. Es multiplataforma y puede detectar automáticamente el tipo de hash.

Funcionalidades clave:

- **Soporte para múltiples hashes:** Reconoce y crackea cientos de tipos de hashes y cifrados.
- **Ataques de diccionario:** Utiliza listas de palabras (diccionarios) para probar contraseñas comunes.
- **Ataques de fuerza bruta:** Prueba todas las combinaciones posibles de caracteres hasta encontrar la correcta.
- **Modo single crack:** Utiliza información del propio nombre de usuario y otros datos para generar permutaciones y adivinar la contraseña. [24]

Usos e Implementación en el Mundo Real

- **Auditoría de Contraseñas Internas:** Un administrador puede conseguir los hashes de las contraseñas de los usuarios en un servidor, usando John the Ripper para encontrar aquellas que son débiles o comunes.

- **Recuperación de Contraseñas:** Si un administrador olvida alguna contraseña de una cuenta o de algun archivo cifrado, se puede usar John para recuperarlas.
- **Análisis Forense:** Si al terminar un ciberataque, se han dejado los archivos hashes, se puede utilizar John para descifrarlos y ver credenciales comprometidas. [30]

7. Hashcat

Considerado como uno de los crackers de contraseñas más rápidos del mundo, Hashcat es una herramienta avanzada que aprovecha la potencia de las tarjetas gráficas (GPU) para acelerar enormemente el proceso de cracking. Es la herramienta preferida para romper hashes complejos y largos en un tiempo reducido.

Funcionalidades clave:

- **Cracking basado en GPU:** Utiliza el poder de procesamiento paralelo de las GPUs para realizar miles de millones de intentos por segundo.
- **Soporte para más de 300 algoritmos:** Es compatible con una vasta gama de algoritmos de hash, incluyendo MD5, SHA, WPA/WPA2, bcrypt y muchos más.
- **Ataques basados en reglas:** nos deja combinar diccionarios con reglas complejas para así conseguir millones de variaciones de posibles contraseñas.
- **Ataques por máscara:** Si se conoce la estructura de las contraseñas, podemos utilizar una máscara para que hashcat prueba combinaciones que logren coincidir con ese patrón.
- **Múltiples modos de ataque:** Soporta ataques de fuerza bruta, de diccionario, combinados, por máscara y basados en reglas. [25]

Usos e Implementación en el Mundo Real

- **Pruebas de Penetración a gran escala:** Cuando se tienen base de datos, con millones de hashes de usuarios, hashcat es una herramienta ideal para procesar esa cantidad de información.
- **Respuesta a Incidentes:** Puede ser utilizado en analisis forense, pero es ideal cuando los hashes son muy robustos, es decir que requieren una gran capacidad de computo para su descifración.

- **Pruebas de Contraseñas de Wi-Fi:** Hashcat es muy eficaz para descifrar contraseñas Wi-Fi se puede capturar el handshake de autenticación de una red para encontrar la contraseña offline. [31]

8. Aircrack-ng

Aircrack-ng es una suite completa de herramientas para auditar la seguridad de redes inalámbricas (Wi-Fi). Permite a los profesionales de la seguridad probar la resistencia de sus redes Wi-Fi, centrándose principalmente en el monitoreo, el ataque, las pruebas y el cracking de claves WEP y WPA/WPA2-PSK.

Funcionalidades clave:

- **Airodump-ng:** Captura paquetes 802.11 para recolectar información sobre puntos de acceso y clientes.
- **Aireplay-ng:** Inyecta tráfico en la red para diversos fines, como generar tráfico para ataques WEP o realizar ataques de desautenticación.
- **Aircrack-ng:** Crackea las claves WEP y WPA/WPA2-PSK a partir de los paquetes capturados.
- **Airmon-ng:** Pone las tarjetas de red en modo monitor, un requisito para la captura de paquetes. [26]

9. OWASP ZAP (Zed Attack Proxy)

OWASP ZAP es un escáner de seguridad para aplicaciones web de código abierto y gratuito, mantenido por la comunidad de OWASP (Open Web Application Security Project). Es una excelente alternativa a herramientas comerciales como Burp Suite y es muy popular tanto entre principiantes como expertos. Al igual que Burp Suite, actúa como un proxy "man-in-the-middle" para interceptar y analizar el tráfico.

Funcionalidades clave:

- **Escáner pasivo y activo:** Analiza las respuestas del servidor en busca de fallos (pasivo) y lanza ataques conocidos contra la aplicación (activo).
- **Spider tradicional y AJAX:** Rastrea la aplicación para descubrir todo su contenido, incluyendo el generado dinámicamente.
- **Soporte para WebSockets:** Permite probar la seguridad de las comunicaciones en tiempo real.

- **Marketplace de complementos:** Su funcionalidad puede extenderse fácilmente con una gran variedad de add-ons. [27]

10. SQLmap

SQLmap es una herramienta de código abierto que automatiza el proceso de detección y explotación de vulnerabilidades de inyección SQL y la toma de control de servidores de bases de datos. Es una herramienta indispensable para cualquier pentester que audite aplicaciones web. Puede detectar y explotar una amplia gama de motores de bases de datos como MySQL, Oracle, PostgreSQL, Microsoft SQL Server, etc.

- **Funcionalidades clave:**
 - **Detección y explotación automática:** Identifica y explota vulnerabilidades de inyección SQL basadas en error, booleanas, de tiempo, UNION, y fuera de banda.
 - **Enumeración de la base de datos:** Permite listar bases de datos, tablas, columnas y obtener todos sus datos.
 - **Acceso al sistema de archivos:** En ciertas configuraciones, permite leer y escribir archivos en el servidor.
 - **Ejecución de comandos:** Puede llegar a obtener una shell interactiva en el sistema operativo del servidor si las condiciones lo permiten. [28]

Usos e Implementación en el Mundo Real

- **Auditoría de Aplicaciones Web:** Es la principal herramienta usada por un pentester, se le brinda la URL por ejemplo de un formulario o buscador, con SQLmap se analiza los parametros para detectar si uno es vulnerable.
- **Exfiltración de Datos:** Se detecta una vulnerabilidad y con SQLmap enumeramos todas las bases de datos, ver tablas y sus columnas para robar la información que se podría robar a las empresas.
- **Escalada de Privilegios:** Si se configura mal un servidor con SQLmap podemos leer archivos sensibles que esten en el sistema operativo o incluso tomar control del servidor que aloja la aplicación web. [32]

11. Hydra (THC – Hydra)

Hydra es una de las herramientas de hacking más utilizadas ya que nos permite realizar ataques de fuerza bruta de manera online. A comparación de herramientas como John The Ripper o HashCat que funcionan de manera offline es decir que trabajan sobre hashes con los que ya contamos. Hydra actúa de forma que intenta adivinar las contraseñas objetivo probando muchos tipos de combinaciones de usuarios y contraseñas diferentes de forma rápida y paralela conectándose por medio de servicio en la red, como lo puede ser un login de algún sitio web o por medio de protocolos de red como SSH y FTP.

Usos y Aplicaciones

Hydra tiene bastantes usos, pero uno de sus usos principales es el auditar la seguridad y robustez de las contraseñas de algún tipo de servicio que pueda estar expuesto.

Pruebas de Penetración (Pentesting): Estas pruebas sirven para comprobar si existen contraseñas que puedan ser débiles en servicios como:

- **SSH, FTP, Telnet:** Son puertas de entrada para administrar servidores. Si Hydra encuentra que el usuario root tiene la contraseña 123456, el pentester gana control total del servidor.
- **Servicios de correo (POP3, IMAP, SMTP):** Estos tres son los protocolos que usan los clientes de correo para hablar con el servidor de correo.
- **Bases de datos:** Si se deja alguna base de datos expuesta. Un pentester usaría Hydra para ver si el usuario root de la base de datos tiene una contraseña en blanco o débil. Si entra, puede comprometer información confidencial.
- **Servicios de Windows (SMB, RDP):** RDP es el Escritorio Remoto. Si Hydra encuentra que el Administrator tiene la contraseña Empresa2025, el pentester puede ver el escritorio del servidor como si estuviera sentado frente a él.
- **Formularios de login web:** Este es el más común. Es el panel de admin de un sitio web, tu correo web, o cualquier página que pida usuario y clave. Hydra automatiza el proceso de rellenar ese formulario miles de veces para lograr tener acceso al sitio.

Auditoría de Políticas: Demostrar el riesgo de no tener políticas de bloqueo de cuentas tras varios intentos fallidos. [2]

Ventajas

Versatilidad: Soporta una lista enorme de protocolos de red.

Velocidad: Es extremadamente rápida, ya que puede lanzar múltiples intentos de conexión en paralelo.

Flexibilidad: Permite usar listas de usuarios y listas de contraseñas o incluso generar contraseñas sobre la marcha.

Desventajas

Ruidosa: Genera una cantidad masiva de tráfico de red y entradas de log (registros). Es muy fácil de detectar por sistemas de detección de intrusos (IDS/IPS) o herramientas como *Fail2Ban*.

Dependiente del Entorno: Si el servicio bloquea la IP tras 3-5 intentos fallidos, Hydra se vuelve ineficaz.

No rompe hashes: Solo prueba credenciales contra un servicio vivo

¿Cómo defenderse de Hydra?

El objetivo es hacer que el ataque de fuerza bruta sea inútil o imposible.

- **Política de Bloqueo de Cuentas:** Bloquear una cuenta o IP después de 5-10 intentos fallidos.
- **Autenticación de Múltiples Factores (2FA):** Requerir un código del teléfono además de la contraseña.
- **Usar CAPTCHA:** Añadir la prueba de No soy un robot en los formularios web para detener scripts.
- **Instalar Fail2Ban:** Usar un software que detecta y bloquea IPs que realizan ataques de fuerza bruta.

12. Acunetix (DAST - Pruebas de Aplicaciones Web)

Acunetix es una herramienta commercial y que está automatizada por DAST, estas siglas significan Pruebas Dinámicas de Seguridad de Aplicaciones. Acunetix en palabras simples es un escaner de vulnerabilidades que está diseñado específicamente para detectar fallos de seguridad en aplicaciones, sitios web y API's. Esta herramienta simula un ataque externo, donde se intenta romper la aplicación desde fuera, esto sin la necesidad de ver el código fuente.

Usos y aplicaciones

El enfoque principal de Acunetix es detectar y encontrar nuevas vulnerabilidades:

Detección de OWASP: Es experto en encontrar las vulnerabilidades más críticas, como:

- Inyección SQL (SQLi)
- Cross-Site Scripting (XSS)
- Server-Side Request Forgery (SSRF)
- Inclusión de Archivos (LFI/RFI)

Escaneo de APIs: Prueba APIs REST, SOAP y GraphQL en busca de fallos de autenticación o lógica.

Escaneo de Single Page Applications (SPAs): Puede escanear aplicaciones modernas construidas con frameworks como React, Angular o Vue.js, que son difíciles para escáneres más antiguos.

Integración DevSecOps: Se integra en pipelines de CI/CD para escanear aplicaciones automáticamente antes de que pasen a producción.

Ventajas

- **Alta Precisión (Bajos Falsos Positivos):** Es muy bueno para confirmar vulnerabilidades, reduciendo el tiempo de verificación manual.
- **Velocidad:** Es uno de los escáneres DAST más rápidos del mercado.
- **Interfaz de Usuario (UI) Sencilla:** Es muy fácil de usar, configurar escaneos y generar reportes ejecutivos.

- **Tecnología IAST (AcuSensor):** Ofrece un sensor opcional (IAST) que se instala en el servidor para dar un análisis "desde dentro" y "desde fuera" a la vez, mejorando la detección.

Desventajas

- **Comercial (Costoso):** Es una herramienta de pago y su licencia puede ser cara para individuos o pequeñas empresas.
- **Enfoque Limitado:** Está 100% enfocado en la web. No es la herramienta ideal para escanear tu infraestructura de red (servidores, routers).
- **No ve el Código:** Al ser DAST puro, puede pasar por alto vulnerabilidades que solo son visibles analizando el código (SAST).
- **"Caja Negra":** Al ser un producto comercial, su funcionamiento interno no es modificable.

13. OpenVas Escáner de Red e Infraestructura

OpenVas es un framework de código abierto utilizado para el escaneo de vulnerabilidades, OpenVas es el sucesor de Nessus, después de que este se volviera comercial.

La especialidad de esta herramienta es el escaneo de infraestructura y de red, esto para buscar y detectar vulnerabilidades conocidas CVEs en los sistemas operativos y servicios.

Usos y aplicaciones

El enfoque principal de OpenVas es detectar vulnerabilidades a nivel de red y de infraestructura:

- **Auditoría de Red:** Escanea rangos de IP para descubrir qué hosts están activos, qué puertos tienen abiertos y qué servicios (SSH, FTP, HTTP, SMB) están corriendo.
- **Detección de CVEs:** Compara las versiones del software y servicios encontrados (ej. "Apache 2.4.49") contra su enorme base de datos de vulnerabilidades conocidas (NVTs - Network Vulnerability Tests).

- **Análisis de Configuración:** Busca configuraciones inseguras, como permisos incorrectos, uso de contraseñas débiles (en servicios como FTP) o certificados SSL obsoletos.
- **Gestión de Parches:** Es fundamental para que los administradores de sistemas sepan qué servidores necesitan actualizaciones de seguridad urgentes.

Ventajas

- **Cobertura Masiva de Red:** Su base de datos de pruebas (NVTs) es extensa y se actualiza diariamente, cubriendo miles de CVEs en todo tipo de software (Linux, Windows, Cisco, etc.).
- **Personalizable:** Al ser *open source*, se puede adaptar, modificar e integrar con otras herramientas de forma muy flexible.
- **Reportes Detallados:** Ofrece reportes muy técnicos sobre las vulnerabilidades encontradas y cómo solucionarlas.

Desventajas

- **Falsos Positivos:** Tiende a generar más falsos positivos que las herramientas comerciales, requiriendo más verificación manual.
- **Enfoque de Red, no de Aplicación:** Aunque puede escanear un servidor web (puerto 80/443), no está diseñado para entender la lógica de una aplicación web (iniciar sesión, probar formularios).
- **Interfaz (GSA):** La interfaz web (Greenbone Security Assistant) es potente pero menos intuitiva que la de Acunetix.

¿Como defenderse de OpenVas?

La defensa efectiva contra OpenVas no consiste en bloquear el escáner, sino en utilizar sus reports para remediar las vulnerabilidades detectadas.

- **Gestión de Parches:** Es la defensa número uno. Actualizar inmediatamente el software obsoleto que OpenVas reporta.
- **Cerrar Puertos (Mínimo Privilegio):** Usar un *firewall* para cerrar todos los puertos que no sean estrictamente necesarios

- **Deshabilitar Servicios Innecesarios:** Apagar servicios que no se usen (como FTP, Telnet, SMB).
- **Configuraciones Seguras:** Bastonar los servicios que sí se usan deshabilitar el *login* de root por contraseña en SSH.
- **Monitoreo Continuo:** Ejecutar escaneos de vulnerabilidad periódicamente.

1. Categorización de las Herramientas

No todas las herramientas sirven para lo mismo. Se pueden clasificar según la fase de un test de penetración en la que se utilizan:

- **Reconocimiento:** Herramientas para recolectar información pasivamente sobre el objetivo sin interactuar directamente con él. Ejemplos: Maltego, theHarvester.
- **Escaneo:** Usadas para descubrir sistemas, puertos y servicios activos en la red del objetivo. El ejemplo por excelencia es Nmap.
- **Análisis de Vulnerabilidades:** Identifican debilidades conocidas en los sistemas escaneados. Aquí entra Nessus.
- **Explotación:** Diseñadas para tomar ventaja de las vulnerabilidades y ganar acceso. El rey de esta categoría es Metasploit.
- **Post-Explotación:** Herramientas que se usan una vez que se ha ganado acceso para escalar privilegios, moverse por la red o extraer información. Metasploit también tiene módulos para esto.
- **Cracking de Contraseñas:** Especializadas en descifrar hashes de contraseñas. Ejemplos claros son John the Ripper y Hashcat.
- **Análisis de Aplicaciones Web:** Enfocadas en la seguridad de sitios y aplicaciones web. Burp Suite y OWASP ZAP son las principales.
- **Análisis de Redes Inalámbricas:** Para auditar la seguridad de redes Wi-Fi. La suite Aircrack-ng es el estándar.

¿Cómo se Utilizan Estas Herramientas en la Práctica?

Nessus

Instalación y Configuración: Primero debemos instalar Nessus en un servidor o máquina virtual. La versión Nessus Essentials es gratuita y perfecta para aprender. Accedes a él a través de tu navegador web.

Crear un Nuevo Escaneo: Dentro de la interfaz, seleccionamos "New Scan". Nessus te ofrece plantillas preconfiguradas. Una muy común para empezar es Basic Network Scan. [33]

Definir el Objetivo: En la configuración del escaneo, introduces los objetivos. Esto puede ser una sola dirección IP, un rango de IPs o un dominio.

Lanzar y Monitorear: Guardas y lanzas el escaneo. Nessus comenzará a "conversar" con cada uno de los objetivos, probando miles de vulnerabilidades conocidas de su base de datos. Puedes ver el progreso en tiempo real.

Analizar el Reporte: Al finalizar, Nessus genera un reporte interactivo. Las vulnerabilidades se clasifican por severidad: Crítica, Alta, Media, Baja e Informativa. Al hacer clic en una vulnerabilidad, Nessus te da:

- Una descripción detallada del fallo.
- El puerto y servicio afectado.
- La solución recomendada
- Enlaces a CVEs y otras referencias para más información. [34]

John the Ripper

Es una herramienta de línea de comandos. Su uso es un proceso más manual. [35]

1. **Obtener los Hashes:** El primer paso es tener un archivo con los hashes de las contraseñas que quieres auditar, un administrador de sistemas podría con autorización de copiar los hashes del archivo /etc/shadow de un servidor Linux.
2. **Ejecutar John:** Abres una terminal y ejecutas el comando básico. John es inteligente y probará varios modos automáticamente.
3. **Utilizar Modos Específicos:** Modo Diccionario, es el más común. Se usa una lista de palabras para ver si alguna coincide.
4. **Modo Incremental (Fuerza Bruta):** Si el diccionario falla, puedes decirle a John que pruebe todas las combinaciones de caracteres. Es mucho más lento.
5. **Ver los Resultados:** Para ver las contraseñas que John ha logrado descifrar, usas el comando --show.

El resultado mostrará el hash y, a su lado, la contraseña en texto plano que ha encontrado. [36]

Hashcat

Hashcat también es de línea de comandos, pero requiere ser más específico. Su velocidad es su gran ventaja. [37]

1. **Preparación:** Necesitas un archivo con los hashes de las contraseñas
2. **Identificar el Tipo de Hash:** Debemos decirle a Hashcat qué tipo de hash estás atacando. Cada tipo tiene un número.
3. **Ejecutar el Ataque:** La estructura del comando es hashcat -m [modo] -a [ataque] [archivo_hash] [diccionario/máscara].
4. **Ataque de Máscara (Fuerza Bruta Inteligente) (-a 3):** Si conocemos que la contraseña son 8 números, el ataque es mucho más rápido.
5. **Revisar los Resultados:** Hashcat guarda las contraseñas encontradas en un archivo llamado hashcat.potfile. [38]

SQLmap

SQLmap automatiza la búsqueda y explotación de inyecciones SQL. Es extremadamente potente. Solo debemos usar esta herramienta contra sistemas para los que tienes permiso explícito y por escrito. Su uso no autorizado es ilegal. [39]

1. **Encontrar un Punto de Entrada:** Buscas una URL en tu aplicación web que use parámetros. El ejemplo clásico es uno que muestra un producto: `http://sitiodoprueba.com/productos.php?id=5`
2. **Análisis Básico:** El primer comando es para que SQLmap analice esa URL y vea si es vulnerable. SQLmap empezará a hacer pruebas y realizará preguntas interactivas.
3. **Enumerar la Base de Datos:** Si se encuentra una vulnerabilidad, el siguiente paso es ver qué hay dentro. Usaremos el siguiente comando para listar las tablas de la base de datos: `sqlmap -u "http://sitiodoprueba.com/productos.php?id=5" -D nombre_de_la_bd -tables`
4. **Extraer los Datos (Dumping):** Finalmente, para demostrar el impacto, puedes extraer la información de todas las columnas "usuario" y "contraseña" de la tabla "usuarios" en la base de datos. [40]

SQLmap mostrará en la terminal toda la información contenida en esas columnas.

Ventajas, Desventajas y su Impacto

Nessus

Ventajas

- **Cobertura Exhaustiva:** Se base de datos tienes miles de vulnerabilidades, esto puede permitir tener una gran gama de fallos en los sistemas operativos, software y dispositivos en la red.
- **Facilidad de Uso:** La interfaz es muy amigable, lo que permite a los usuarios configurar y lanzar análisis de forma más eficiente sin tener que ser expertos.
- **Reportes Detallados y Accionables:** Genera informes que listan los problemas y los clasifican por peligrosidad y también brinda soluciones claras a estos problemas.
- **Automatización:** Permite gestionar escaneos cada determinado tiempo lo que es excelente para detectar vulnerabilidades. [41]

Desventajas

- **Costo Elevado:** Aunque haya una versión gratuita las versiones profesionales necesarias para entornos empresariales tienen un costo de licencia bastante costoso.
- **Falsos Positivos:** Puede mostrar vulnerabilidades que en realidad no existe o que no es explotable.
- **Intrusivo:** Al realizar escaneos completos consume muchos recursos de la red y de los sistemas, pudiendo llegar a causar caídas en los servicios si no se usa con cuidado.

Impacto en la Ciberseguridad

El impacto de Nessus fue revolucionado. Antes de su popularización, buscar vulnerabilidades era un proceso manual que era muy costoso y tardado. Nessus agilizo el escaneo de vulnerabilidades, permitiendo identificar y corregir fallos de seguridad de manera más eficiente. Fue el pilar fundamental de los programas modernos para la gestión de vulnerabilidades. [42]

SQLmap

Ventajas

- **Automatización y Eficiencia:** Realiza en unos cuantos minutos un trabajo que a una persona le tomaría horas o días. Ya que puede probar cientos de técnicas de inyección de forma automática.
- **Extremadamente Potente:** Además de detectar fallos los explota al máximo, ya que extraer bases de datos completas, puede acceder al

sistema de archivos de algún servidor e incluso obtener una shell de comandos lo que se puede traducir en un control total del sistema.

- **Amplio Soporte:** Tiene compatibilidad con una gran variedad de sistemas de gestión de bases de datos como lo pueden ser MySQL, Oracle, PostgreSQL, SQL Server, etc. [43]

Desventajas

- **Muy Ruidoso:** Esto significa que se genere una cantidad masiva de tráfico inusual en la red. Lo que la hace más fácil de detectar por los Firewalls de Aplicaciones Web (WAF) y Sistemas de Detección de Intrusos (IDS).
- **Curva de Aprendizaje:** Aunque puede ser sencillo de usar, dominar sus funciones avanzadas como lo pueden ser sus técnicas de evasión de firewalls requiere un conocimiento más avanzado.
- **Herramienta de un Solo Propósito:** Es el mejor para realizar inyecciones SQL pero no tiene ningún otro uso.

Impacto en la Ciberseguridad

SQLmap fue quien reveló la gravedad de las carencias y la frecuencia de las vulnerabilidades de una inyección SQL. Demuestra cómo un simple formulario en una página web podía traducirse en un robo de toda la base de datos de una empresa. Esto forzó que el desarrollo de software tuviera que ser mucho más robusto y que las validaciones y sanitizaciones de las entradas del usuario tuvieran que ser mejores, todo esto en conjunto impulsando la práctica de codificación más segura. [44]

John the Ripper

Ventajas

- **Facilidad de Uso y Autodetección:** Su mayor ventaja fue su capacidad para detectar automáticamente el tipo de hash que se le proporciona. Solo se necesita el archivo de hashes y John se encarga de lo demás, lo que simplifica enormemente el proceso.
- **Alta Compatibilidad:** Es multiplataforma lo que significa que funciona en una gran parte de los sistemas operativos y arquitecturas comunes, incluyendo Linux, Windows, macOS y muchos tipos de Unix. No se necesita de un hardware específico de GPU, lo que lo vuelve más accesible.
- **Modos de Ataque Inteligentes:** Además de los ataques de diccionario y fuerza bruta, su famoso modo single crack es muy

eficaz. Se utiliza la información del propio nombre de usuario y otros datos relacionados para poder generar permutaciones y adivinar las contraseñas, esto da resultados muy rápidos para contraseñas débiles.

- **Fiabilidad y Madurez:** Es un proyecto con décadas de desarrollo, es estable y está muy bien documentado. Lo que lo vuelve una herramienta de confianza en la comunidad de ciberseguridad. [45]

Desventajas

- **Lentitud Relativa en Hashes Modernos:** Su mayor desventaja es el uso del hardware se basa principalmente en el procesador. Para hashes que son más complejos y modernos diseñados para ser computacionalmente más caros.
- **Menos Eficiente para Ataques a Gran Escala:** Si se tiene una base de datos con millones de hashes lo que se traduce en un ciberataque masivo, su menor velocidad lo hace menos práctico y eficiente que otras herramientas modernas.
- **El Desarrollo es Menos Rápido:** A medida que el ritmo de incorporación de nuevos algoritmos de hash puede ser más lento en comparación con otras herramientas.

Impacto en la Ciberseguridad

El impacto que tuvo John the Ripper fue fundamental porque sentó las bases para las contraseñas modernas. Fue de las primeras herramientas disponibles que permitió la seguridad para auditar de forma mas segura y conseguir la fortaleza de las contraseñas en sus propios sistemas. [46]

Hashcat

Ventajas

- **Velocidad Insuperable:** Su principal ventaja es el procesamiento en paralelo de la GPU, lo que permite probar millones de contraseñas por segundo, una cifra inalcanzable para otras herramientas.
- **Soporte Masivo de Algoritmos:** Tiene una alta compatibilidad con cualquier tipo de hashes y algoritmos de cifrado, desde los más antiguos como MD5, hasta los más modernos, incluyendo contraseñas de Wi-Fi, cualquier hash de sistemas operativos y de gestores de contraseñas.
- **Ataques de Máscara:** Se pueden definir patrones de contraseñas lo que se traduce en reducción en el tiempo de búsqueda.

- **Ataques Basados en Reglas:** Puede tomar una lista de palabras y aplicar cientos de mutaciones para crear miles de millones de contraseñas probables.
- **Desarrollo Activo:** Al ser un proyecto moderno su comunidad es muy activa, esto garantiza actualizaciones constantes, soporte de nuevos algoritmos y optimizaciones en el rendimiento. [47]

Desventajas

- **Alta Dependencia del Hardware:** Para aprovechar al máximo potencial, necesitamos tarjetas gráficas potentes. Esto se traduce en un gran costo económico esto es una barrera para usuarios con hardware estándar.
- **Complejidad y Curva de Aprendizaje:** La sintaxis es más robusta y compleja que la de otras herramientas. Se debe identificar y especificar manualmente el modo de hash y el modo de ataque esto es complejo para principiantes.
- **Consumo de Recursos:** Hace que la GPU trabaje al 100% de su capacidad durante horas o días lo que consume una gran cantidad de energía eléctrica y genera mucho calor, por esto se requiere una buena ventilación y una fuente de alimentación buena.

Impacto en la Ciberseguridad

El impacto de Hashcat ha cambiando el paradigma de la seguridad de las contraseñas ya que demuestra de forma práctica que las políticas de contraseñas que antes se consideraban seguras ahora son obsoletas. Esto aignifico que tales contraseñas podían ser descifradas en cuestión de horas o días. [48]

2 Metodología

1. SQLMap

SQLMap es una herramienta ideal para detectar y explotar vulnerabilidades de inyección SQL en su mayoría en aplicaciones web. Su uso principal es realizar pruebas de forma automatizada, identifica el tipo de base de datos usada y extrae toda la información de cada tabla, soporta diversos vectores de ataque, es muy usado para auditorias de seguridad y porque es de código abierto.

```
brandon@2806-10a6-0015-9062-0a00-27ff-fe95-673c:~$ sudo dnf update -y
[sudo] password for brandon:
AlmaLinux 9 - AppStream          411 B/s | 4.2 kB  00:10
AlmaLinux 9 - AppStream          1.0 MB/s | 20 MB  00:19
AlmaLinux 9 - BaseOS             9.8 kB/s | 3.8 kB  00:00
AlmaLinux 9 - BaseOS            2.0 MB/s | 29 MB  00:14
AlmaLinux 9 - Extras            296 B/s | 3.3 kB  00:11
AlmaLinux 9 - Extras            2.0 kB/s | 20 kB  00:10
Dependencias resueltas.
=====
Paquete                Arq.  Versión                Repositorio  Tam.
=====
Instalando:
kernel                 x86_64 5.14.0-570.51.1.el9_6  baseos      1.8 M
Actualizando:
NetworkManager         x86_64 1:1.52.0-7.el9_6      baseos      2.3 M
NetworkManager-adsl    x86_64 1:1.52.0-7.el9_6      baseos       32 k
NetworkManager-bluetooth x86_64 1:1.52.0-7.el9_6      baseos       58 k
NetworkManager-config-server noarch 1:1.52.0-7.el9_6      baseos       18 k
NetworkManager-libnm   x86_64 1:1.52.0-7.el9_6      baseos      1.9 M
NetworkManager-team    x86_64 1:1.52.0-7.el9_6      baseos       37 k
NetworkManager-tui     x86_64 1:1.52.0-7.el9_6      baseos      246 k
NetworkManager-wifi    x86_64 1:1.52.0-7.el9_6      baseos       80 k
```

Para utilizar SQLMap utilizamos la URL del sitio web que vamos atacar esto lo hacemos con el comando -u desde la terminal, después apuntamos a la base de datos con el comando DBS y ejecutamos, al terminar la inyección se nos muestran información del sitio como lo son tecnologías, versiones y las tablas de la base de datos.

```
brandon@2806-10a6-0015-9062-0a00-27ff-fe95-673c:~$
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: cat=1 AND (SELECT 5555 FROM (SELECT(SLEEP(5)))OHDG)

Type: UNION query
Title: Generic UNION query (NULL) - 11 columns
Payload: cat=1 UNION ALL SELECT NULL,NULL,NULL,NULL,NULL,NULL,NULL,NULL,CONCAT(0x716b707671,0x414d496967504e4b6268655a695a716b6f58664750434f506f697452526754715a49557874706a43,0x716b716b71),NULL-- --
----
[18:36:24] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL >= 5.6
[18:36:24] [INFO] fetching database names
available databases [2]:
[*] acuart
[*] information_schema

[18:36:25] [INFO] fetched data logged to text files under '/home/brandon/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 18:36:25 /2025-10-12/
brandon@2806-10a6-0015-9062-0a00-27ff-fe95-673c:~$
```

2. John The Ripper

John the Ripper es una herramienta eficaz para la auditoría de contraseñas, su enfoque principal es el detectar contraseñas débiles. Su uso en auditorías se debe a su facilidad al momento de usarla, su capacidad para trabajar con distintos formatos de hashes y archivos de contraseñas del sistema, y su soporte para ataques de diccionario y fuerza bruta. Es muy utilizada en entornos académicos y profesionales de ciberseguridad, especialmente en sistemas Linux, y al ser de código abierto permite adaptaciones y mejoras según las necesidades.

```
brandon@2806-10a6-0015-9062-0a00-27ff-fe95-673c:~$ sudo dnf install snapd -y
Nada por hacer.
¡Listo!
[brandon@2806-10a6-0015-9062-0a00-27ff-fe95-673c ~]$ sudo dnf install snapd -y
Última comprobación de caducidad de metadatos hecha hace 2:49:07, el dom 12 oct 2025 20:48:58.
Dependencias resueltas.
=====
Paquete                Arquitectura  Versión      Repositorio  Tam.
=====
Instalando:
snapd                  x86_64       2.71-0.el9   epel          19 M
Instalando dependencias:
snap-confine           x86_64       2.71-0.el9   epel          3.1 M
snapd-selinux          noarch       2.71-0.el9   epel          97 k
xdelta                  x86_64       3.1.0-17.el9 epel          87 k
=====
Resumen de la transacción
=====
Instalar 4 Paquetes

Tamaño total de la descarga: 22 M
Tamaño instalado: 74 M
Descargando paquetes:
[1-3/4]: snap-confine-2. 0% [ ] --- B/s | 0 B --- ETA
```

Ahora es necesario crear un archivo llamado diccionario.txt aquí almacenamos las contraseñas que vamos a usar, después creamos otro archivo con el hash que vamos a utilizar una vez hecho esto, utilizamos el comando, John-the-ripper --wordlist seguido de un signo de igual, después de este pondremos el nombre de nuestro diccionario seguido del nombre de nuestro archivo de hash, al ejecutar las siguientes instrucciones se nos mostrara en la terminal un mensaje con detalles acerca de los algoritmos usamos en nuestro diccionario y un mensaje de "session completed" que nos indicará que se ha usado John The Ripper de manera correcta

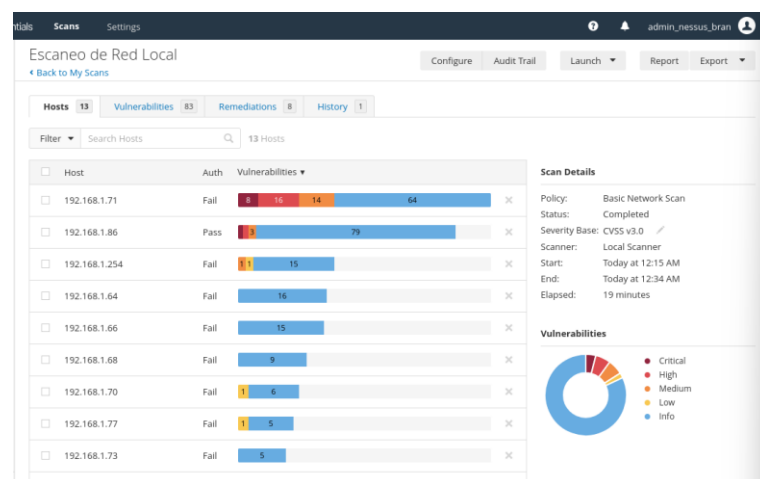
```
[brandon@2806-10a6-0015-9062-0a00-27ff-fe95-673c ~]$ echo "123456" > diccionario.txt
[brandon@2806-10a6-0015-9062-0a00-27ff-fe95-673c ~]$ john-the-ripper --wordlist=diccionario.txt
hash_a_crackear.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-opencl"
Use the "--format=md5crypt-opencl" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Will run 2 OpenMP threads
Note: Passwords longer than 5 [worst case UTF-8] to 15 [ASCII] rejected
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
Warning: Only 1 candidate buffered, minimum 48 needed for performance.
0g 0:00:00:00 DONE (2025-10-13 00:14) 0g/s 50.00p/s 50.00c/s 50.00C/s 123456
Session completed.
[brandon@2806-10a6-0015-9062-0a00-27ff-fe95-673c ~]$
```


3. Nessus

Nessus es una herramienta especializada en el escaneo y detección de vulnerabilidades en sistemas, redes y aplicaciones. Se usa principalmente para automatizar el proceso de identificación de fallas de seguridad, configuraciones incorrectas y software desactualizado. Nessus cuenta con una amplia base de datos de vulnerabilidades, genera reportes detallados y es ampliamente utilizado en auditorías de seguridad y evaluaciones de riesgo, lo que la hace una herramienta clave para la prevención de ataques.

```
brandon@2806-10a6-0015-9062-0a00-27ff-fe95-673c:~/Descargas
[brandon@2806-10a6-0015-9062-0a00-27ff-fe95-673c ~]$ cd Descargas
[brandon@2806-10a6-0015-9062-0a00-27ff-fe95-673c Descargas]$ sudo rpm -ivh Nessus-10.10.0-el9.x86_64.rpm
advertencia:Nessus-10.10.0-el9.x86_64.rpm: EncabezadoV4 RSA/SHA256 Signature, ID de clave
2f12069d: NOKEY
Verifying... ##### [100%]
Preparando... ##### [100%]
Actualizando / instalando... ##### [100%]
1:Nessus-10.10.0-el9
Unpacking Nessus Core Components...
{"procid":3866,"time":1761539853963,"tid":1,"msg":"FIPS module Module_Integrity HMAC test
FAIL","severity":"INFO"}
{"procid":3866,"time":1761539853963,"tid":1,"msg":"FIPS module Install_Integrity HMAC tes
t FAIL","severity":"INFO"}
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
Pass
ECDSA : (PCT_Signature) : Pass
```

Para realizar el escaneo de una red con Nessus debemos seleccionar la parte donde se nos muestran las plantillas de escaneo disponibles aquí seleccionamos “Basic New Scan”, al hacerlo se nos mostrara un formulario donde debemos darle un nombre al escaneo y colocar la IP de la red en la parte de targets listo esto iniciamos con el escaneo esto puede tardar un poco dependiendo de nuestro equipo, al finalizar se nos mostrará un reporte con todas las vulnerabilidades detectadas en nuestra red y podremos ver a detalle cada una de estas.



4. Metasploit Framework

Metasploit Framework es una de las plataformas más completas para el desarrollo y ejecución de exploits en pruebas de penetración. Es usada debido a su gran cantidad de módulos que permiten explotar vulnerabilidades, realizar ataques post-explotación y evaluar el impacto real de una falla de seguridad. Es ampliamente utilizado en pentesting profesional, permite la automatización de ataques y es de código abierto, lo que facilita su extensión y personalización según el entorno evaluado.

```
brandon@2806-10a6-0015-ce33-0a00-27ff-fe95-673c:~  
[brandon@2806-10a6-0015-ce33-0a00-27ff-fe95-673c ~]$ sudo ./msfinstall  
Checking for and installing update..  
Adding metasploit-framework to your repository list..Esperando a que finalice el  
proceso con pid 6527.  
Metasploit 34 kB/s | 353 kB 00:10  
Última comprobación de caducidad de metadatos hecha hace 0:00:01, el lun 10 nov  
2025 17:58:45.  
Dependencias resueltas.  
=====
```

Paquete	Arq.	Versión	Repositorio	Tam.
Instalando:				
metasploit-framework	x86_64	6.4.98~20251110055718~1rapid7-1.el6	metasploit	375 M

```
Resumen de la transacción  
=====
```

Instalar	1 Paquete
Tamaño total de la descarga: 375 M	
Tamaño instalado: 817 M	
Descargando paquetes:	
metasploit-framework-6.4.98~20251110055718~1rap	7.2 MB/s 375 MB 00:51

Para realizar una simulación de ataque debemos mover el modulo que vamos a utilizar con el comando use después utilizamos el comando set seguido de la URL del sitio objetivo y iniciamos el escaneo con el comando run, al finalizar se listan todos los directorios existentes, la estructura que tiene el sitio web, con esto ya podría realizar una prueba de pentesting.

```
msf auxiliary(scanner/http/dir_scanner) > set RHOSTS testphp.vulnweb.com  
RHOSTS => testphp.vulnweb.com  
msf auxiliary(scanner/http/dir_scanner) > run  
[*] Detecting error code  
[*] Using code '404' as not found for 44.228.249.3  
[+] Found http://testphp.vulnweb.com:80/CVS/ 200 (44.228.249.3)  
[+] Found http://testphp.vulnweb.com:80/Connections/ 200 (44.228.249.3)  
[+] Found http://testphp.vulnweb.com:80/Templates/ 200 (44.228.249.3)  
[+] Found http://testphp.vulnweb.com:80/admin/ 404 (44.228.249.3)  
[+] Found http://testphp.vulnweb.com:80/cgi-bin/ 403 (44.228.249.3)  
[+] Found http://testphp.vulnweb.com:80/images/ 404 (44.228.249.3)  
[+] Found http://testphp.vulnweb.com:80/secured/ 200 (44.228.249.3)  
[*] Scanned 1 of 1 hosts (100% complete)  
[*] Auxiliary module execution completed  
msf auxiliary(scanner/http/dir_scanner) >  
msf auxiliary(scanner/http/dir_scanner) >
```

3 Conclusiones

Al concluir esta investigación, se pueden apreciar en su totalidad las grandes ventajas de conocer y aplicar los conceptos básicos en el ámbito de la ciberseguridad y la importancia que estos pueden tener en nuestro día a día.

No solo nos permiten detectar o defendernos de ataques sino también para prevenirlos en el futuro, la correcta implementación y el adecuado uso de las herramientas junto con la aplicación correcta de las medidas es fundamental para poder tener una red protegida y mantener la integridad de toda la información que se encuentra en ella.

A medida que los sistemas de software modernos van evolucionando y mejorando también crecen las vulnerabilidades que puedan tener contar con un equipo de personas capacitadas y que cuenten con los conocimientos técnicos necesarios es fundamental para poder prevenir y actuar ante cualquier posible ciberataque en el futuro.

A medida que la ciberseguridad avanza, se vuelve un pilar fundamental a medida que las tecnológicas van avanzando, por lo que invertir en la investigación de nuevas medidas y en el desarrollo de sistemas que sean más seguros que los actuales será clave para poder hacerle frente a los nuevos retos de ciberseguridad que surjan en el futuro.

En el camino que esta tomando la ciberseguridad será de gran importancia hacer conciencia en la gente sobre la seguridad digital, tanto en las empresas, organizaciones y usuarios comunes, sugiriendo y promoviendo buenas prácticas y también el uso responsable y consciente de la tecnología para minimizar los riesgos de sufrir algún ciberataque.

Bibliografía

- Aircrack-ng. (15 de Diciembre de 2022). *Documentation*. Obtenido de Aircrack-ng: <https://www.aircrack-ng.org/doku.php>
- Cisco. (17 de Abril de 2023). *Cisco*. Obtenido de Cisco: <https://www.cisco.com/site/us/en/learn/topics/security/what-is-cybersecurity.html>
- DataScientest. (1 de Enero de 2022). *Hashcat: ¿qué es? (o All about hashcat)*. Obtenido de DataScientest: <https://datascientest.com/en/all-about-hashcat>
- DataScientest. (30 de Marzo de 2023). *Hashcat: ¿qué es? (o All about hashcat)*. Obtenido de DataScientest: <https://datascientest.com/es/hashcat-que-es>
- Elastic. (22 de Junio de 2022). *Elastic*. Obtenido de Elastic: <https://www.elastic.co/es/what-is/cybersecurity>
- eSecurityPlanet. (18 de Agosto de 2022). *John the Ripper*. Obtenido de eSecurityPlanet: <https://www.esecurityplanet.com/products/john-the-ripper/>
- ESET. (19 de Julio de 2024). *¿Qué es un hacker y qué hace?* Obtenido de ESET Latinoamérica: <https://www.eset.com/latam/blog/cultura-y-seguridad-digital/que-es-un-hacker-y-que-hace/>
- ESET. (30 de Octubre de 2024). *Incidentes de ciberseguridad en 2024 en América Latina*. Obtenido de WeLiveSecurity: <https://www.welivesecurity.com/es/cibercrimen/incidentes-ciberseguridad-2024-america-latina/>
- ESET. (10 de Marzo de 2024). *Tipos de hacker: conoce las diferencias*. Obtenido de WeLiveSecurity: <https://www.welivesecurity.com/es/otros-temas/tipos-hacker-diferencias/>
- Grupo, S. (29 de Enero de 2021). *Hacking ético: Procedimiento, técnicas y recomendaciones*. Obtenido de S2 Grupo: <https://s2grupo.es/hacking-etico-procedimiento-tecnicas-recomendaciones/>
- Grupo, S. (21 de Julio de 2022). *Hacking ético: Procedimiento, técnicas y recomendaciones*. Obtenido de S2 Grupo: <https://s2grupo.es/hacking-etico-procedimiento-tecnicas-recomendaciones/>
- HackerOne. (18 de Abril de 2024). *OWASP ZAP: 6 Key Capabilities and Quick Tutorial*. Obtenido de HackerOne: <https://www.hackerone.com/knowledge-center/owasp-zap-6-key-capabilities-and-quick-tutorial>

Hackmetrix. (21 de Febrero de 2023). *Ejemplos de ciberataques*. Obtenido de Blog de Hackmetrix: <https://blog.hackmetrix.com/ejemplos-de-ciberataques/>

hashcat. (28 de Enero de 2023). *hashcat wiki*. Obtenido de hashcat: <https://hashcat.net/wiki/>

hashcat. (21 de Noviembre de 2024). *hashcat wiki*. Obtenido de hashcat: <https://hashcat.net/wiki/>

IBM. (21 de Abril de 2023). *Ciberhacking*. Obtenido de IBM Think: <https://www.ibm.com/mx-es/think/topics/cyber-hacking>

IBM. (18 de Mayo de 2024). *Ethical Hacking*. Obtenido de IBM Think: <https://www.ibm.com/think/topics/ethical-hacking>

IBM. (11 de Octubre de 2024). *Prueba de penetración*. Obtenido de IBM Think: <https://www.ibm.com/mx-es/think/topics/penetration-testing>

IBM. (8 de Noviembre de 2025). *1*. Obtenido de IBM: <https://www.ibm.com/mx-es/topics/network-security>

IBM. (18 de Mayo de 2025). *Hacking ético*. Obtenido de IBM: <https://www.ibm.com/mx-es/topics/ethical-hacking>

ICM. (21 de Noviembre de 2024). *Herramientas de auditoría de SQL Injection. SQLmap*. Obtenido de ICM: <https://www.icm.es/2022/12/16/herramientas-de-auditoria-de-sql-injection-sqlmap/>

KeepCoding. (13 de Marzo de 2021). *Escaneo básico con Nessus*. Obtenido de KeepCoding Blog: <https://keepcoding.io/blog/escaneo-basico-con-nessus/>

KnowledgeHut. (27 de Octubre de 2023). *What is Wireshark?* Obtenido de KnowledgeHut Blog: <https://www.knowledgehut.com/blog/security/what-is-wireshark>

Malwarebytes. (24 de Enero de 2022). *¿Qué es el hacking ético?* Obtenido de Malwarebytes: <https://www.malwarebytes.com/es/cybersecurity/basics/what-is-ethical-hacking>

Mico, T. (8 de Noviembre de 2025). *Trend Micro*. Obtenido de Trend Micro: https://www.trendmicro.com/es_mx/what-is/network-security.html

Nmap. (1 de Septiembre de 2023). *Nmap: Free Security Scanner For Network Exploration & Security Audits*. Obtenido de Nmap: <https://www.g2.com/products/tenable-nessus/reviews>

Openwall. (9 de Julio de 2022). *John the Ripper Examples*. Obtenido de Openwall: <https://www.openwall.info/wiki/john/examples>

Openwall. (1 de Julio de 2023). *John the Ripper Documentation (o John the Ripper)*. Obtenido de Openwall: <https://www.openwall.com/john/doc/>

Openwall. (19 de Febrero de 2024). *John the Ripper Documentation (o John the Ripper)*. Obtenido de Openwall: <https://www.openwall.com/john/>

OWASP. (2 de Julio de 2022). *SQL Injection*. Obtenido de OWASP: https://owasp.org/www-community/attacks/SQL_Injection

OWASP. (22 de Enero de 2024). *OWASP Top Ten (o Principales Vulnerabilidades Web)*. Obtenido de OWASP: https://owasp.org/www-community/attacks/SQL_Injection

Paterva. (20 de Octubre de 2021). *Maltego Documentation (o Inteligencia de Fuentes Abiertas)*. Obtenido de Maltego: <https://www.openwall.info/wiki/john>

Point, C. (8 de Noviembre de 2025). *Check Point*. Obtenido de Check Point: <https://www.checkpoint.com/es/cyber-hub/network-security/what-is-network-security/>

PortSwigger. (22 de Febrero de 2023). *Burp Suite Overview (o Funcionalidades de Burp Suite)*. Obtenido de PortSwigger: <https://docs.tenable.com/Nessus.htm>

Rapid7. (22 de Julio de 2022). *Metasploit Framework Overview*. Obtenido de Rapid7 Documentation: <https://docs.rapid7.com/metasploit/msf-overview/>

Rapid7. (17 de Julio de 2025). *Metasploit Framework: Getting Started*. Obtenido de Rapid7 Docs: <https://hashcat.net/wiki/doku.php?id=hashcat>

Security, O. (25 de Julio de 2024). *Kali Linux: Advanced Penetration Testing Distribution*. Obtenido de Kali Linux: <https://www.geeksforgeeks.org/john-the-ripper-a-password-cracking-tool/>

Services, A. W. (12 de Marzo de 2024). *AWS*. Obtenido de AWS: <https://aws.amazon.com/es/what-is/cybersecurity/>

Snyk. (25 de Marzo de 2023). *Ethical hacking tools: 10 herramientas de piratería ética*. Obtenido de Snyk Blog: <https://snyk.io/es/blog/ethical-hacking-tools/>

sqlmapproject. (21 de Septiembre de 2024). *Usage*. Obtenido de GitHub (sqlmapproject): <https://github.com/sqlmapproject/sqlmap/wiki/Usage>

Support, M. (10 de Noviembre de 2024). *Microsoft Support*. Obtenido de Microsoft Support: <https://support.microsoft.com/es-es/topic/-qu%C3%A9-es-la-ciberseguridad-8b6efd59-41ff-4743-87c8-0850a352a390>

Target, H. (12 de Agosto de 2025). *SQLMap Tutorial*. Obtenido de Hacker Target: <https://hackertarget.com/sqlmap-tutorial/>

Tenable. (16 de Marzo de 2024). *¿Qué es Nessus? (o Características de Nessus)*. Obtenido de Tenable: <https://www.hypr.com/security-encyclopedia/hashcat>

Tenable. (8 de Abril de 2024). *Nessus Documentation: Get Started*. Obtenido de Tenable Docs: <https://docs.tenable.com/nessus/Content/GetStarted.htm>

Tenable. (25 de Mayo de 2024). *Nessus Professional*. Obtenido de Tenable: <https://es.tenable.com/products/nessus>

Tenable. (12 de Marzo de 2025). *Nessus Professional*. Obtenido de Tenable: <https://www.tenable.com/products/nessus/nessus-professional>

THC. (12 de Julio de 2025). *Hydra: The Great Password Attack Tool*. Obtenido de THC (The Hacker's Choice): <https://github.com/sqlmapproject/sqlmap/wiki/Usage>

UNAM. (25 de Julio de 2022). *Hackers*. Obtenido de Instituto de Ingeniería
UNAM: [https://www.iingen.unam.mx/es-
mx/AlmacenDigital/CapsulasTI/Paginas/hackers.aspx](https://www.iingen.unam.mx/es-mx/AlmacenDigital/CapsulasTI/Paginas/hackers.aspx)